

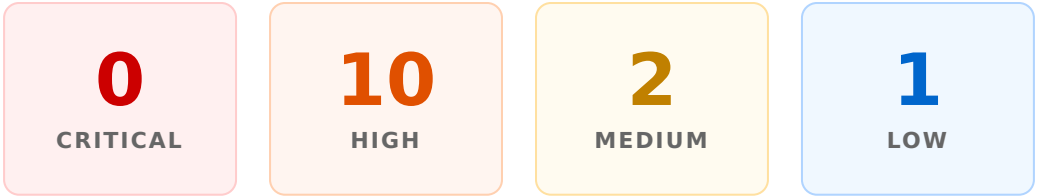
SECURITY AUDIT REPORT

SecurePipeline Audit Tool

CI/CD & Infrastructure Security Assessment

REPOSITÓRIO	DATA	TOTAL DE FINDINGS
tests	19 May 2026	13

Sumário Executivo



DETALHES

Findings

HIGH Segredo hardcoded: Generic Password	
FICHEIRO	app.py:3
DETALHE	Possível Generic Password detectado → DB_PASSWORD = "****r_secret_password_123****"
REMEDIÇÃO	Remove o valor do código. Usa variáveis de ambiente (os.enviror ou um gestor de segredos como Azure Key Vault.

HIGH Segredo hardcoded: Generic API Key	
FICHEIRO	app.py:5
DETALHE	Possível Generic API Key detectado → API_KEY = "****SyB1234567890abcdefghijklmnopqrstuvwxyz****"
REMEDIÇÃO	Remove o valor do código. Usa variáveis de ambiente (os.enviror ou um gestor de segredos como Azure Key Vault.

HIGH**Possível segredo em ARG****FICHEIRO**

Dockerfile:5

DETALHE

'ARG DB_PASSWORD=mysecretpassword' — visível no histórico da imagem.

REMEDIÇÃO

Usa Docker BuildKit secrets em vez de ARG/ENV para credenciais.

HIGH**Vulnerabilidade em flask==0.12.0: GHSA-562c-5r94-xh97****FICHEIRO**

requirements.txt

DETALHE

Flask is vulnerable to Denial of Service via incorrect encoding of JSON data (CVE: GHSA-562c-5r94-xh97)

REMEDIÇÃO

Atualiza 'flask' para a versão mais recente. Consulta: <https://osv.dev/vulnerability/GHSA-562c-5r94-xh97>

HIGH**Vulnerabilidade em flask==0.12.0: GHSA-5wv5-4vpf-pj6m****FICHEIRO**

requirements.txt

DETALHE

Pallets Project Flask is vulnerable to Denial of Service via Unexpected memory usage (CVE: GHSA-5wv5-4vpf-pj6m)

REMEDIÇÃO

Atualiza 'flask' para a versão mais recente. Consulta: <https://osv.dev/vulnerability/GHSA-5wv5-4vpf-pj6m>

HIGH**Vulnerabilidade em flask==0.12.0: GHSA-68rp-wp8r-4726****FICHEIRO**

requirements.txt

DETALHE

Flask session does not add `Vary: Cookie` header when accessed in some ways (CVE: GHSA-68rp-wp8r-4726)

REMEDIÇÃO

Atualiza 'flask' para a versão mais recente. Consulta: <https://osv.dev/vulnerability/GHSA-68rp-wp8r-4726>

HIGH**Vulnerabilidade em flask==0.12.0: GHSA-m2qf-hxjv-5gpg****FICHEIRO**

requirements.txt

DETALHE

Flask vulnerable to possible disclosure of permanent session cookie due to missing Vary: Cookie header (CVE: GHSA-m2qf-hxjv-5gpg)

REMEDIÇÃO

Atualiza 'flask' para a versão mais recente. Consulta: <https://osv.dev/vulnerability/GHSA-m2qf-hxjv-5gpg>

HIGH**Vulnerabilidade em flask==0.12.0: PYSEC-2018-66****FICHEIRO**

requirements.txt

DETALHE

Sem descrição (CVE: PYSEC-2018-66)

REMEDIÇÃO

Atualiza 'flask' para a versão mais recente. Consulta: <https://osv.dev/vulnerability/PYSEC-2018-66>

HIGH**Vulnerabilidade em flask==0.12.0: PYSEC-2019-179****FICHEIRO**

requirements.txt

DETALHE

Sem descrição (CVE: PYSEC-2019-179)

REMEDIÇÃO

Atualiza 'flask' para a versão mais recente. Consulta: <https://osv.dev/vulnerability/PYSEC-2019-179>

HIGH**Vulnerabilidade em flask==0.12.0: PYSEC-2023-62****FICHEIRO**

requirements.txt

DETALHE

Sem descrição (CVE: PYSEC-2023-62)

REMEDIÇÃO

Atualiza 'flask' para a versão mais recente. Consulta: <https://osv.dev/vulnerability/PYSEC-2023-62>

MEDIUM**Imagem com :latest: python:latest****FICHEIRO**

Dockerfile:1

DETALHE

FROM python:latest não é reproduzível.

REMEDIÇÃO

Substitui :latest por uma versão específica.

MEDIUM**Dockerfile sem instrução USER****FICHEIRO**

Dockerfile

DETALHE

Sem USER definido, o processo corre como root por defeito.

REMEDIÇÃO

Adiciona 'RUN useradd -m appuser' e 'USER appuser' antes do CMD.

LOW**ADD para ficheiro local — usa COPY****FICHEIRO**

Dockerfile:7

DETALHE

ADD tem comportamento extra não-óbvio para ficheiros locais.

REMEDIÇÃO

Substitui ADD por COPY para ficheiros locais.